

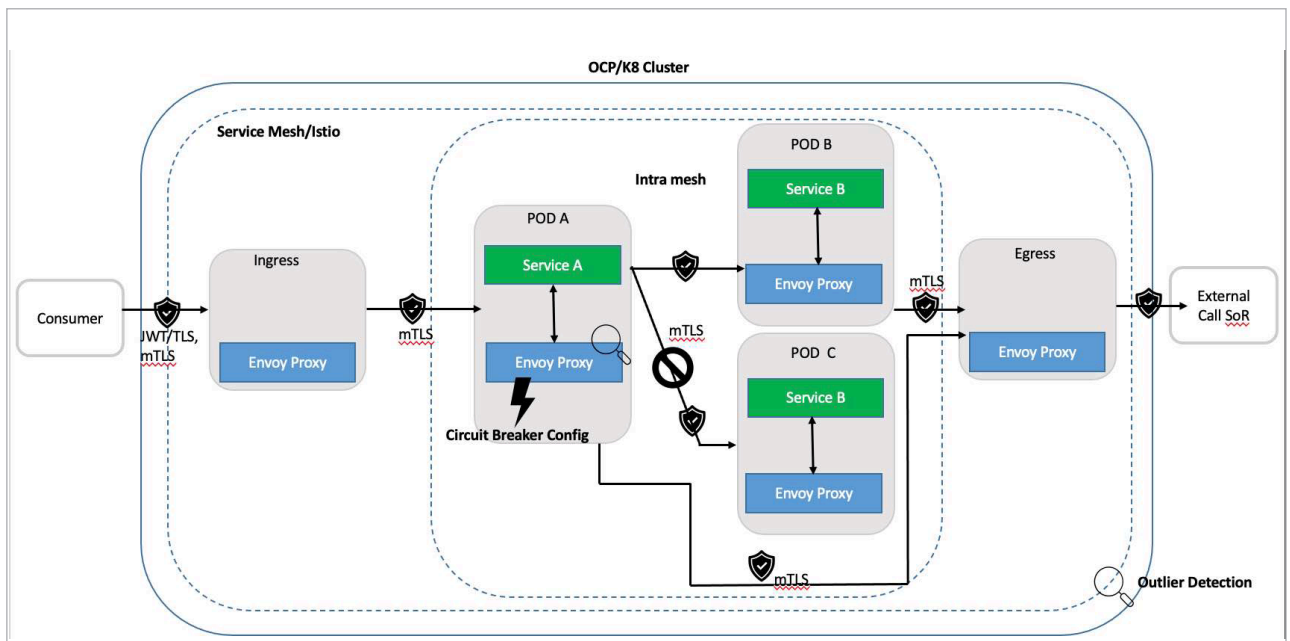


Figure 4: Pool ejection with outlier detection

increase. Also, activities such as certificate management, key management, etc, need to be considered to properly secure services/components. The context of this pattern is adopting a zero trust approach in securing calls made via ingress or egress of the Kubernetes cluster or calls between services within the cluster. Traffic between the pods within the cluster should be treated in the same way as traffic between external components and pods in the cluster. To do all of these, the following needs to be ensured during architecture, service design and implementation:

- All message flows between the services are encrypted.
- Access control is in place to ensure only services that are able to communicate with other services are available.
- Logging and auditing telemetry data is gathered to understand typical traffic behaviour and proactively detect intrusion or retrospectively investigate what has happened.
- Zero-trust approach to protect resources without relying on the position in the network for protections.
- Security at depth to provide multiple layers to protect resources.

Pattern description and solution

Service mesh capabilities configured in the K8 cluster provide multiple capabilities to address the challenges mentioned before. Service mesh with an L7 Application Gateway ensures it acts as a policy enforcement point (PEP) providing a consistent application of authorisation policies between consumers, APIs and SoRs or external systems.

Figure 6 depicts a logical view of the capabilities implemented within service mesh to secure ingress traffic, intra mesh traffic and egress traffic.

The solution and application for each of the above three security enforcement points are described briefly below with respect to the relevant security area.

Security enforcement point: Securing ingress traffic

Security area: Application authentication

Solution: Both the consumer and ingress of service mesh must use certificates signed by the designated CA of the bank/enterprise in mTLS handshake.

Application: Certificates of the ingress gateway are managed by the cert-manager of Kubernetes. It handles issuance and renewal, and manages integration to security vault or any managed service solution such as cloud based key management as service (KMaaS). Internal certificates used for mTLS between envoy proxies should be configured for frequent rotation (e.g., six hours) to mitigate the risk of attackers obtaining service mesh certificates. Gateway certificates should be rotated in line with security standards based on KMaaS certificate's time to live (TTL).

Security area: End user AuthN and AuthZ

Solution: The best practice is that a call from the consumer to ingress contains a JWT access token signed by a recognised authorisation server. The scope within the token will determine whether a request is authorised to access requested resources or not.

Application: Service mesh will validate the JWT's signature based on the preconfigured public certificate in